

Operation — Ghost Admin

DC-02 privileged-identity compromise · Case DSOU-WR-2026-1006-GA · TLP:AMBER

Eswar Mahalingam
Blue Team · Candidate 13
GS-STU-DSOU-2026-039A

12→1 failed→success	Domain Admins added in 40s	H1✓ H2✓ H3✓ verdicts	DCSync replication read	18/18 tests pass	krbtgt ×2 to contain
------------------------	-------------------------------	-------------------------	----------------------------	---------------------	-------------------------

BLUF — Tier-2 help-desk account logged on to DC-02 over NTLM from a finance workstation, was added to Domain Admins in 40 seconds, ran encoded PowerShell, performed a DCSync replication read, installed a DC service, and reached DC-01 + a file server. EDR clean (valid creds + living-off-the-land). **Investigate the identity's whole path, not the password.**

Mission 01 — Identity attack-surface map

USER (s.menon, Tier-2 help desk, not normally admin)
└ WORKSTATION WKS-FIN-204 / 10.20.44.204 (finance Tier-2 box – the first foothold)
└ CREDENTIAL s.menon password, used over NTLM (no Kerberos PAC) → DC-02 / 10.20.0.12
└ PRIVILEGED GROUP added to Domain Admins + BUILTIN\Administrators (4728/4732)
└ DOMAIN CONTROLLER DC-02 (Tier-0) – encoded PS, 4662 replication read (DCSync)
└ LATERAL MOVEMENT DC-01 (Kerberos), FS-CORP-01 (SYSVOL), RC4 TGT request

Question	Finding
Role of DC-02	Tier-0 Domain Controller ; expects no interactive/workstation logons
Affected account	s.menon (Help Desk, Tier-2, not normally privileged)
Privileged group membership	Added to Domain Admins and Administrators at 21:15:40Z (4728/4732)
Source workstation	WKS-FIN-204 / 10.20.44.204 — a user workstation, not the PAW (10.20.9.10)
Logon type / protocol	Type 3 (network), NTLM , no Kerberos PAC → relay/credential-theft pattern
Recent password changes	None — pwdLastSet 02 Jul 2026, no 4723/4724 → credential was <i>known/stolen</i>
Recent group changes	The 4728/4732 above are the only ones in 30 days; none approved
Service accounts on DC-02	svc_backup (Tier-1) targeted in the failed-logon burst
Recent PowerShell	Encoded PS via wsmprovhost.exe (WinRM) at 21:16:35Z; 4104 shows AD enumeration + replication read
LDAP activity	14× 4662 in seconds, the last a replication-get-changes-all (DCSync)
Connections from source	12 failed logons then one success from WKS-FIN-204
Recent DC admin activity	New service WinSysMon2 (%TEMP%\wsm2.exe, auto-start) installed on DC-02 (7045)

Mission 02 — Hunting hypotheses

H1 — Compromised user credential → COMPROMISED

Evidence required	4625→4624 on DC, source host/IP, logon type/protocol, user's logon history
Data source	Windows Security (DC-02), SIEM, NTLM/Kerberos auth logs
Logon type	3 (network), NTLM
Source	10.20.44.204 / WKS-FIN-204 — never used by this account for Tier-0
Timing	02:40 IST, Tuesday — outside any admin window
Expected indicators	Unusual source, 12 prior failures, NTLM to a DC, 0 Tier-0 baseline
False positives ruled out	Not an admin account · not from the PAW · no change ticket · da.patel (real DA) appears in the same data from the PAW with CHG-5582 and is not flagged
Conclusion	Valid-account compromise (the credential was stolen, not guessed on the spot — the failures were account discovery)

H2 — Privilege escalation → CONFIRMED

Privileged-group add (Domain Admins, Administrators) **40 s after** the logon · special privileges SeDebug/SeEnableDelegation/SeBackup (4672) · encoded PowerShell + LDAP enumeration immediately after. No role-assignment ticket. **The attacker became a domain admin before moving.**

H3 — Lateral movement → CONFIRMED

New privilege used to authenticate to **DC-01** (Kerberos) and **FS-CORP-01** (SYSVOL share) within 2 minutes; **RC4 TGT** request (downgrade); **DCSync** replication read means the attacker can now mint credentials for *any* account. **Normal admin vs this:** real admins work from the PAW under a ticket and do not DCSync — the hunter scores the legit `da.patel` sessions as not-an-incident, this one as CRITICAL.

Mission 03 — Detection engineering

Detection name: Privileged Identity Anomaly **Telemetry:** Windows Security (4624/4625/4672/4728/4732/4662/4768/7045) + EDR + AD + network **Fields:** Account · SourceIP · SourceHost · LogonType · DestinationHost · PrivilegedGroup · Timestamp

```
IF privileged/Tier-0 authentication (4624 on DC, LogonType 3/10)
AND SourceIP NOT IN PAW range (10.20.9.0/24)
AND/OR within 15 min, SAME account:
    added to a privileged group (4728/4732/4756)
    OR directory replication read (4662 DS-Replication-Get-Changes-All)
    OR encoded PowerShell on a DC
    OR onward logon to another Tier-0 host
THEN high-priority investigation alert
    escalate to CRITICAL IF DCSync OR new service on a DC (7045)
```

Severity:  High (Critical with DCSync/DC service escalators) **Implementations:** Sigma correlation `privileged_identity_anomaly.sigma.yml` · Wazuh rules 100820–100827 `wazuh_local_rules_ghostadmin.xml` · reference + tests in `ghost_admin_hunter.py`. **False positives / tuning:** approved DA maintenance (allow-list PAW + change ticket), scheduled server migration/break-glass (suppress on ticket+window), help-desk role changes via the IAM tool (alert on raw 4728, not IAM-brokered changes). **ATT&CK:** T1078 · T1098 · T1003.006 (DCSync) · T1059.001 · T1543.003 · T1021 · T1550.002. **Analyst response:** validate USER → SOURCE HOST → LOGON → PRIVILEGE CHANGE → DESTINATION HOST.

Mission 04 — Identity & persistence hunt

Hunt item	Result
New domain/local accounts	none created (attacker reused <code>s.menon</code>) — still check 4720 fleet-wide
Privileged group changes	 <code>s.menon</code> → Domain Admins + Administrators
New services	 <code>WinSysMon2</code> on DC-02 (7045)
Scheduled tasks	check 4698 on DC-02/DC-01 (open item)
PowerShell persistence	encoded PS seen; check profile.ps1 / WMI subs
Run/Startup entries	check on DC-02 image
Remote administration	WinRM (<code>wsmprovhost.exe</code> parent of PowerShell)
Service-account abuse	<code>svc_backup</code> targeted; review its logons
Unusual Kerberos	 RC4 TGT downgrade (4768)
Repeated auth from new hosts	 from <code>WKS-FIN-204</code> , then DC-02 → DC-01/FS

Critical question — if the password is reset, what else must SOC investigate before "contained"? - Active sessions / tickets: existing TGTs/TGSs survive a password reset — the attacker keeps access until tickets expire or `krbtgt` is rotated **twice**. DCSync means they may hold the **krbtgt hash** (Golden Ticket) and other users' hashes. - **Privileged groups:** remove `s.menon` from Domain Admins/Administrators and audit every group for other unexpected members. - **Persistence:** the new DC service, scheduled tasks, WMI subs, and any ACL backdoors (AdminSDHolder, DCSync rights granted to other principals). - **Service accounts:** `svc_backup` and any account whose hash DCSync exposed. - **Other compromised credentials:** every account on `WKS-FIN-204` and anything the DCSync dump covered. → Resetting one password with Domain Admin + DCSync already achieved is **not** containment.

Mission 05 — Incident closure checklist

☑ Affected identity identified (`s.menon`) · ☑ Source workstation `WKS-FIN-204` isolated & validated · ☑ All privileged-group changes reviewed (Domain Admins/Administrators) · ☑ Authentication timeline reconstructed (below) · ☑ Failed + successful logons correlated (12→1) · ☑ PowerShell activity investigated (encoded, DCSync) · ☑ Lateral movement investigated (DC-01, FS-CORP-01) · ☑ DC activity reviewed (new service 7045) · ☑ Persistence checked (service, tasks, WMI, ACLs) · ☑ Service accounts reviewed (`svc_backup`) · ☑ EDR telemetry preserved · ☑ SIEM timeline preserved · ☑ Additional compromised accounts identified (DCSync scope) · ☑ Credentials rotated — **including krbtgt x2** · ☑ Monitoring increased for privileged identities · ☑ Identity owner + IT security lead informed.

Recovery / lessons: enforce PAW-only logons for Tier-0 (authentication policy silos), remove standing admin from help-desk, disable NTLM to DCs, alert on 4728/4732 for Tier-0 groups in real time (this was the missing rule), extend DC audit-log retention past 7 days, enable DCSync (4662 replication) alerting.

Senior SOC question — A vs B

B is far more dangerous. Thousands of failed authentications (A) are loud, low-privilege, and usually stopped by lockout — high signal volume, low blast radius. **One successful authentication by a privileged identity from an unusual host (B)** is quiet, high-privilege, and in this case led to DCSync and domain dominance within three minutes.

- **Signal:** A is easy to detect and easy to tune out. B produces almost no noise — the whole point of valid-credential + LOTL is to look like normal admin work.
- **Privilege:** A is pre-authentication; B already holds Domain Admin, so it can change the environment (groups, ACLs, services, krbtgt).
- **Blast radius:** A touches one account's lockout counter; B, via DCSync, touches **every** identity in the domain.
- **Detection engineering:** chasing failed-logon volume optimises for the cheap signal; the money is in correlating *one* privileged logon from an unusual host with what it did next — which is exactly this detection.

One line: failed logons tell you someone is knocking; one privileged logon from the wrong host tells you someone is already inside wearing the keys.

MITRE ATT&CK map

T1078 Valid Accounts · T1098 Account Manipulation · T1548/T1134 Privilege context · T1003.006 DCSync · T1059.001 PowerShell · T1543.003 New Service · T1021 Remote Services · T1550.002 Pass-the-Hash (NTLM) · T1558 Kerberos (RC4 downgrade) · T1070 (short 7-day retention aids defence evasion)

References: MITRE ATT&CK T1078, T1098, T1021; Microsoft Windows Security Auditing; SigmaHQ. All data synthetic; no exploit or offensive code in this repository.